

Independent Assurance Reports

Document ID	Version	Owner	Effective Date	Framework	Classification
[DOC-ID]	1.0	Head of Internal Audit / Assurance	[Effective Date]	COBIT 2019	Confidential - Internal Use Only

Purpose

This report presents the results of independent assurance activities performed over the organisation's governance and management of enterprise information and technology. It is intended to provide the Board, Audit and Risk Committee, executive management, and relevant control owners with an objective view of whether selected governance practices, management processes, controls, and evidence are designed and operating effectively.

The report supports management oversight by:

- Confirming whether technology governance activities are aligned with enterprise objectives, risk appetite, and agreed performance expectations.
- Identifying control weaknesses, governance gaps, process inefficiencies, and areas of non-conformance.
- Assessing whether accountabilities, decision rights, escalation paths, metrics, and reporting mechanisms are operating as intended.
- Providing practical recommendations and agreed actions to improve control effectiveness, resilience, compliance, value delivery, and risk management.
- Supporting transparency over the status of remediation activities and management accountability.

This report is not intended to replace management's responsibility for designing, operating, monitoring, and improving controls. Independent assurance provides an objective assessment based on evidence available during the reporting period.

Reporting Period & Scope

Reporting Period

Item	Details
Reporting period covered	[Start Date] to [End Date]
Fieldwork period	[Start Date] to [End Date]
Report issue date	[Report Date]
Assurance provider	[Internal Audit Function / External Audit Firm / Independent Assurance Team]
Report sponsor	[Audit and Risk Committee / Chief Audit Executive / Board Sponsor]
Management owner	[Chief Information Officer / Chief Digital Officer / Chief Technology Officer]

Scope of Review

The assurance engagement covered selected governance and management practices relating to information and technology, with emphasis on the reliability of governance oversight, performance reporting, risk management, control monitoring, and improvement tracking.

The review included assessment of the following areas:

Scope Area	Included Activities	Primary Owners
Governance oversight	Review of technology governance forums, decision records, escalation mechanisms, and oversight reporting	Board Technology Committee, Executive Committee, CIO
Risk and control monitoring	Evaluation of how technology risks, control issues, incidents, and exceptions are identified, reported, tracked, and escalated	Risk Management, Technology Risk, Control Owners
Performance and conformance reporting	Assessment of technology metrics, dashboards, key risk indicators, control attestations, and management reporting	IT Governance Office, Enterprise PMO, Service Owners
Assurance coordination	Review of coordination between internal audit, external audit, compliance, risk, security, and operational assurance activities	Internal Audit, Compliance, CISO, Risk Function
Issue and remediation management	Testing of issue logging, ownership assignment, action planning, target dates, closure evidence, and overdue escalation	Control Owners, Risk Function, Internal Audit
Management accountability	Review of defined responsibilities, approvals, action ownership, and evidence of management oversight	Executive Management, Process Owners

In-Scope Business Units and Functions

Business Unit / Function	Included in Review	Notes
Corporate IT	Yes	Core technology governance and service management activities reviewed
Cybersecurity	Yes	Security risk reporting, incidents, and remediation tracking reviewed
Enterprise Risk Management	Yes	Alignment of technology risk reporting with enterprise risk profile reviewed
Internal Audit	Yes	Assurance planning and reporting interfaces reviewed
Compliance	Yes	Regulatory and policy conformance reporting reviewed
Business Operations	Partial	Review limited to technology-related control ownership and issue remediation
Third-party service providers	Partial	Review limited to governance reporting, service performance, and issue escalation evidence

Systems, Tools, and Records Reviewed

The following systems and records were reviewed where relevant and available:

- Governance committee agendas, packs, minutes, and action trackers.
- Risk registers, control libraries, issue logs, and remediation trackers.
- Internal audit reports, external audit reports, regulatory findings, and management responses.
- Technology performance dashboards and service reporting.
- Security incident summaries and trend reports.
- Exception registers and risk acceptance records.
- Policy attestation records and control self-assessments.
- Project and programme reporting for technology-enabled change.
- Third-party performance reports and service review records.
- Evidence supporting closure of prior assurance findings.

Out of Scope

The following were not included in this review unless specifically referenced in the findings:

- Detailed technical penetration testing or vulnerability exploitation.
- Full financial statement audit procedures.
- Re-performance of every operational control across all technology services.
- Source code review.
- Legal interpretation of contractual or regulatory obligations.
- Formal certification readiness assessment.
- Full review of business continuity and disaster recovery testing beyond reporting and oversight evidence.

Limitations

The conclusions in this report are based on:

- Evidence provided by management during the fieldwork period.
- Interviews with selected personnel.
- Sample-based testing rather than complete population testing.
- The operating environment and organisational structure in place during the reporting period.
- The accuracy and completeness of records supplied by process and control owners.

Where evidence was unavailable, incomplete, or inconsistent, this has been reflected in the relevant finding.

Executive Summary

Overall Assurance Opinion

Overall rating: Moderate assurance

The organisation has established core mechanisms for technology governance oversight, risk reporting, issue tracking, and assurance coordination. Governance forums operate regularly, key technology risks are reported to senior stakeholders, and management has made progress in consolidating audit and risk findings into central trackers.

However, the review identified weaknesses in the consistency, completeness, and evidential quality of assurance reporting. Several governance and control monitoring activities are reliant on manual updates, informal follow-up, and inconsistent management attestations. In particular, issue closure evidence is not always independently validated, technology risk reporting lacks consistent linkage to business impact, and assurance activities across the three lines of accountability are not fully coordinated through an integrated plan.

As a result, executive management and governing bodies may not always receive a complete and timely view of technology-related control effectiveness, risk exposure, or remediation progress.

Key Strengths

The review identified the following positive practices:

- Technology governance committees meet on a scheduled basis and maintain records of decisions and actions.
- Technology risk themes are visible in executive-level reporting.
- Internal audit findings are assigned to named management owners with due dates.
- High-priority security and resilience matters are escalated to senior management.
- Service performance reporting is regularly produced for key technology services.
- External audit and regulatory findings are tracked by management.
- The organisation has begun consolidating assurance outputs into a central view.

Summary of Findings

Rating	Number of Findings	Themes
Critical	0	None identified
High	2	Issue closure validation, integrated assurance planning
Medium	4	Risk reporting, control self-assessment quality, metrics, third-party assurance
Low	2	Documentation consistency, meeting action tracking
Improvement Opportunity	2	Dashboard enhancement, knowledge management

High-Priority Findings

Ref.	Finding Title	Rating	Management Owner	Target Date
IA-01	Issue closure evidence is inconsistent and not always independently validated	High	[Role / Owner]	[Date]
IA-02	Assurance activities are not fully coordinated through an integrated assurance plan	High	[Role / Owner]	[Date]

Overall Conclusion

The organisation has a functioning technology assurance and oversight environment, but further maturity is required to provide consistently reliable assurance to governing bodies. Improvements should focus on strengthening evidence standards, integrating assurance planning, improving risk-based reporting, and establishing clearer accountability for the quality and timeliness of remediation.

Management has accepted the findings in this report and has agreed to implement the actions documented in the Recommendations & Actions section.

Methodology

Assurance Approach

The engagement was conducted using a risk-based assurance approach aligned to recognised governance, risk, control, and audit practices. The review considered both design effectiveness and operating effectiveness.

The work was performed through:

- Review of governance and management documentation.
- Interviews with executive stakeholders, process owners, control owners, risk personnel, audit personnel, and selected business representatives.
- Walkthroughs of issue management, risk reporting, committee reporting, and assurance coordination processes.
- Sample testing of audit findings, management actions, control attestations, risk records, and governance decisions.
- Review of performance metrics, management dashboards, and escalation records.
- Comparison of observed practices against the organisation's governance expectations, policy requirements, risk appetite, and accepted good practice.

Testing Performed

Test Area	Test Objective	Sample / Evidence Reviewed
Governance forum operation	Confirm whether oversight forums meet as scheduled, receive relevant information, and record decisions	Committee packs, agendas, minutes, attendance logs, action trackers
Issue management	Confirm whether findings are logged, assigned, risk-rated, tracked, escalated, and closed with adequate evidence	Audit issue log, remediation plans, closure evidence, overdue reports
Assurance coordination	Confirm whether assurance activities are planned and coordinated to avoid gaps or duplication	Audit plans, compliance plans, risk review schedules, management monitoring plans
Risk reporting	Confirm whether technology risks are reported with clear ownership, business impact, trends, and treatment status	Risk registers, executive risk reports, board packs, key risk indicators
Control monitoring	Confirm whether controls are periodically assessed and results are reliable	Control self-assessments, attestations, testing evidence, exception reports
Third-party assurance	Confirm whether supplier assurance results are reviewed and acted upon	Service review packs, supplier reports, assurance summaries, issue logs
Prior finding follow-up	Confirm whether previous findings were remediated and whether closure was supported by evidence	Prior reports, action closure records, validation notes

Rating Definitions

Findings have been rated using the following criteria:

Rating	Definition	Management Response Expectation
Critical	A severe control failure or governance breakdown that creates immediate and material risk to the organisation, customers, operations, compliance posture, or strategic objectives	Immediate executive attention, urgent containment, formal recovery plan, and frequent progress reporting
High	A significant weakness that may materially affect risk management, control reliability, decision-making, or compliance if not remediated promptly	Management action plan required, senior owner assigned, progress tracked to completion
Medium	A control weakness or process gap that increases risk but is not expected to cause immediate material impact if managed appropriately	Action plan required with defined owner and target date
Low	A minor weakness, inconsistency, or documentation gap with limited risk impact	Remediate through routine process improvement
Improvement Opportunity	A recommended enhancement to improve maturity, efficiency, insight, or consistency	Management to consider and implement where beneficial

Evidence Reliability Considerations

The following factors were considered when evaluating evidence:

- Whether the evidence was system-generated or manually prepared.
- Whether records were complete, dated, approved, and traceable.
- Whether evidence demonstrated performance of a control rather than only intent.
- Whether management assertions were supported by independent records.
- Whether closure evidence addressed the root cause of the original issue.
- Whether reports were produced consistently over time.
- Whether metrics were defined, repeatable, and subject to quality review.

Detailed Findings / Results (with structure)

Finding IA-01 - Issue Closure Evidence Is Inconsistent and Not Always Independently Validated

Field	Detail
Rating	High
Area	Issue and remediation management
Owner	[Role / Owner]
Target remediation date	[Date]
Status	Open

Condition

The review identified that issue closure evidence is not consistently retained, validated, or linked to the original finding and agreed action. In several sampled cases, issues were marked as closed based on management confirmation without sufficient evidence to demonstrate that the remediation had been fully implemented and was operating effectively.

Examples observed included:

- Closure notes stating “completed” without supporting documentation.
- Evidence showing that a document had been updated, but no evidence that the revised process had been communicated or implemented.
- Remediation actions closed without independent review by risk, compliance, internal audit, or another appropriate assurance function.
- Target dates extended multiple times without clear rationale or senior approval.
- Action descriptions that did not fully address the root cause of the original finding.

Criteria

Effective assurance reporting requires reliable issue lifecycle management. Findings should remain open until management can demonstrate that agreed actions have been completed and that the underlying risk has been reduced to an acceptable level. Closure should be supported by appropriate evidence and, for significant findings, independent validation.

Cause

The issue closure process does not define minimum evidence requirements by finding severity. Responsibilities for validating closure are not consistently documented, and the central tracker does not require mandatory evidence fields before an issue can be closed.

Impact

If issues are closed without sufficient validation, management and governing bodies may receive an inaccurate view of control effectiveness and residual risk. This may result in unresolved weaknesses remaining undetected, repeat findings, delayed remediation, and reduced confidence in assurance reporting.

Evidence Reviewed

Evidence Item	Observation
Audit issue tracker	Closure status updated for sampled issues, but supporting evidence was inconsistent
Closure evidence files	Some files contained incomplete or indirect evidence
Management action plans	Several actions did not clearly map to root cause
Committee reports	Closed issue counts reported without evidence quality indicators
Interview records	Stakeholders confirmed closure validation practices vary by team

Recommendation

Define and implement a standard issue closure and validation process. The process should include evidence standards, closure approval requirements, validation responsibilities, and escalation rules for overdue or repeatedly extended actions.

Finding IA-02 - Assurance Activities Are Not Fully Coordinated Through an Integrated Assurance Plan

Field	Detail
Rating	High
Area	Assurance coordination
Owner	[Role / Owner]
Target remediation date	[Date]
Status	Open

Condition

The organisation performs several assurance activities across internal audit, risk management, compliance, cybersecurity, technology operations, external audit, and supplier oversight. However, these activities are not consolidated into a single integrated assurance plan that maps coverage to key technology risks, critical services, regulatory obligations, and management priorities.

The review found:

- Separate assurance plans maintained by different functions.
- Limited visibility of combined assurance coverage for technology risks.
- Potential duplication of assurance work in some areas.
- Limited assurance coverage over certain third-party and cloud service risks.
- No routine executive-level view of assurance gaps, overlaps, and planned coverage.

Criteria

Effective governance requires coordinated assurance that provides decision-makers with a clear view of whether key risks and controls are being independently reviewed. Assurance planning should be risk-based, coordinated across functions, and periodically reviewed by senior management.

Cause

No single function has been assigned responsibility for maintaining an integrated assurance view across technology-related assurance activities. Existing planning cycles are function-specific and not formally aligned.

Impact

Without integrated assurance planning, the organisation may over-assess lower-risk areas while under-assessing material risks. This can reduce efficiency, create assurance fatigue, and leave governing bodies without a complete view of coverage.

Evidence Reviewed

Evidence Item	Observation
Internal audit plan	Contains technology audit activity but not full combined assurance coverage
Compliance monitoring plan	Maintained separately with limited technology risk mapping
Cybersecurity assurance schedule	Focused on security control testing but not integrated with audit planning
Supplier review schedule	Incomplete mapping to criticality and risk
Executive reporting	Does not provide a consolidated assurance coverage map

Recommendation

Establish an integrated technology assurance plan covering internal audit, risk, compliance, cybersecurity, operations, supplier assurance, and external reviews. The plan should be risk-based, approved by appropriate governance forums, and updated regularly.

Finding IA-03 - Technology Risk Reporting Does Not Consistently Link Risks to Business Impact

Field	Detail
Rating	Medium
Area	Risk and control monitoring
Owner	[Role / Owner]
Target remediation date	[Date]
Status	Open

Condition

Technology risks are reported to management forums, but risk descriptions, impact assessments, and treatment updates are not always expressed in business terms. Some risks are described primarily as technical issues without clear explanation of potential operational, financial, customer, regulatory, or strategic impact.

Observed inconsistencies included:

- Risk ratings not always supported by current evidence or trend data.
- Treatment plans not consistently linked to measurable risk reduction.

- Limited reporting of residual risk after remediation actions.
- Key risk indicators not consistently defined or threshold-based.
- Some risks remained static across reporting periods despite changes in environment or control status.

Criteria

Risk reporting should enable informed decisions by presenting technology risks in a way that clearly explains business impact, ownership, trend, treatment status, and required decisions.

Cause

Risk reporting templates allow free-text updates and do not require standard fields for business impact, residual risk, trend, and treatment effectiveness.

Impact

Senior stakeholders may not have sufficient insight to prioritise investment, accept residual risk, challenge treatment plans, or identify emerging exposures.

Evidence Reviewed

Evidence Item	Observation
Technology risk register	Risk descriptions and treatment updates varied in quality
Executive risk reports	Business impact not consistently stated
Risk committee minutes	Some risks discussed without documented decisions or challenge
Key risk indicator dashboard	Thresholds not consistently defined

Recommendation

Enhance technology risk reporting templates to include business impact, current exposure, residual risk, risk trend, treatment status, key decision points, and owner accountability.

Finding IA-04 - Control Self-Assessments Are Not Supported by Consistent Evidence Standards

Field	Detail
Rating	Medium
Area	Control monitoring
Owner	[Role / Owner]
Target remediation date	[Date]
Status	Open

Condition

Control self-assessments are performed by selected process and control owners, but the supporting evidence varies significantly in quality. In some cases, attestations were based on owner judgement rather than documented test results or control performance records.

Examples included:

- Control owners confirming control operation without sample evidence.

- Evidence files that did not align to the control period under review.
- Inconsistent use of pass, fail, partial, and not applicable ratings.
- Limited review or challenge of completed self-assessments.
- No defined sampling guidance for control owners.

Criteria

Control self-assessments should be evidence-based, repeatable, and subject to appropriate review. Ratings should be consistently applied and supported by records that demonstrate actual control performance.

Cause

The control self-assessment process lacks detailed guidance on evidence expectations, sampling, rating definitions, and review responsibilities.

Impact

Management may place reliance on control assessment results that are incomplete, inconsistent, or not representative of actual control performance.

Evidence Reviewed

Evidence Item	Observation
Control self-assessment returns	Evidence quality varied by owner
Attestation records	Some attestations lacked supporting documentation
Review notes	Limited evidence of second-level review
Control guidance	Evidence and sampling standards not sufficiently defined

Recommendation

Develop standard guidance for control self-assessments, including evidence requirements, sampling expectations, rating definitions, reviewer responsibilities, and escalation rules for failed or unsupported controls.

Finding IA-05 - Technology Metrics Are Reported but Not Consistently Linked to Objectives and Thresholds

Field	Detail
Rating	Medium
Area	Performance and conformance reporting
Owner	[Role / Owner]
Target remediation date	[Date]
Status	Open

Condition

Technology performance dashboards are produced regularly, but metrics are not always linked to specific governance objectives, service commitments, risk appetite, or decision thresholds. Some metrics are reported without explanation of whether performance is acceptable, deteriorating, or requiring management action.

Observed examples included:

- Metrics reported as point-in-time values without trend analysis.
- No defined threshold for red, amber, or green status in some reports.
- Limited commentary explaining root cause of adverse movement.
- Metrics included because they are available rather than because they support decision-making.
- Inconsistent ownership of metric accuracy and commentary.

Criteria

Performance reporting should provide meaningful insight into whether technology services, controls, and improvement activities are achieving intended outcomes. Metrics should be defined, owned, threshold-based, and actionable.

Cause

There is no central catalogue of approved governance and management metrics for technology reporting. Reporting packs have evolved over time and include a mix of operational, risk, project, and compliance measures with varying levels of definition.

Impact

Decision-makers may be unable to determine whether performance is acceptable, whether intervention is needed, or whether risks are increasing.

Evidence Reviewed

Evidence Item	Observation
Technology dashboard	Metrics varied in definition and threshold usage
Service performance reports	Trends available for some services but not all
Governance committee packs	Commentary not consistently action-oriented
Metric ownership records	Ownership unclear for selected metrics

Recommendation

Create a technology metrics catalogue that defines each metric, owner, source, calculation method, threshold, reporting frequency, intended audience, and required management action when thresholds are breached.

Finding IA-06 - Third-Party Assurance Results Are Not Consistently Integrated into Management Reporting

Field	Detail
Rating	Medium
Area	Third-party assurance
Owner	[Role / Owner]
Target remediation date	[Date]
Status	Open

Condition

The organisation receives service reports, performance reports, audit summaries, security attestations, and other assurance materials from selected third-party technology providers. However, these outputs are not consistently assessed, risk-rated, tracked, or incorporated into overall technology governance reporting.

The review found:

- Supplier assurance reports retained in contract or vendor management repositories but not always reviewed by control owners.
- Exceptions in supplier reports not consistently logged in the central issue tracker.
- Limited linkage between supplier findings and internal risk reporting.
- Inconsistent evidence of management review of supplier assurance reports.
- No standard process to determine whether supplier assurance is sufficient based on service criticality.

Criteria

Third-party assurance should be reviewed and acted upon where suppliers support important technology services, data processing, security operations, or business processes. Supplier issues should be assessed for organisational impact and tracked to resolution.

Cause

Supplier assurance review responsibilities are distributed across procurement, vendor management, technology, security, and business owners without a consistent process or reporting standard.

Impact

Material supplier risks may not be escalated, tracked, or remediated in a timely manner. Management may lack visibility of control weaknesses affecting outsourced or cloud-based services.

Evidence Reviewed

Evidence Item	Observation
Supplier service reports	Reviewed for major suppliers, but evidence inconsistent
Vendor management records	Assurance documents retained but not always risk-assessed
Issue tracker	Supplier findings not consistently logged
Service review minutes	Supplier control issues not consistently escalated

Recommendation

Implement a standard third-party assurance review process, including intake, ownership, risk assessment, issue logging, escalation, and reporting requirements for suppliers supporting important services.

Finding IA-07 - Governance Meeting Actions Are Not Consistently Tracked to Closure

Field	Detail
Rating	Low
Area	Governance oversight
Owner	[Role / Owner]
Target remediation date	[Date]

Field	Detail
Status	Open

Condition

Governance committee minutes capture decisions and actions, but action tracking practices vary across forums. Some action logs do not consistently record owners, due dates, status, dependencies, or closure notes.

Criteria

Governance actions should be clearly documented, assigned, monitored, and closed with sufficient evidence or rationale. This supports accountability and enables effective follow-up.

Cause

Meeting administration practices are not standardised across technology governance forums.

Impact

Actions may be delayed, overlooked, or closed without adequate transparency. This may reduce the effectiveness of governance oversight.

Evidence Reviewed

Evidence Item	Observation
Committee minutes	Actions documented inconsistently
Action logs	Some actions lacked due dates or status updates
Governance terms of reference	Action tracking expectations not consistently defined

Recommendation

Standardise action tracking across governance forums using a common template and minimum data requirements.

Finding IA-08 - Assurance Documentation Is Not Consistently Organised for Traceability

Field	Detail
Rating	Low
Area	Assurance documentation
Owner	[Role / Owner]
Target remediation date	[Date]
Status	Open

Condition

Assurance records are retained across multiple repositories and naming conventions vary. In some cases, evidence could not be quickly traced from report conclusion to supporting documentation.

Criteria

Assurance documentation should be organised, complete, and traceable so that conclusions, management responses, and closure decisions can be independently reviewed.

Cause

There is no common evidence repository structure or naming standard for technology assurance activities.

Impact

Evidence retrieval may be inefficient, and the organisation may find it more difficult to demonstrate control operation, remediation, or oversight during future audits or regulatory reviews.

Evidence Reviewed

Evidence Item	Observation
Shared drive folders	Inconsistent folder structure
Audit evidence requests	Some evidence took extended time to locate
Report workpapers	Traceability varied by engagement

Recommendation

Define a standard repository structure and file naming convention for assurance records, including minimum retention and access requirements.

Improvement Opportunity IA-09 - Enhance Executive Dashboards for Assurance and Remediation Insight

Field	Detail
Rating	Improvement Opportunity
Area	Reporting and analytics
Owner	[Role / Owner]
Target date	[Date]
Status	Open

Observation

Executive dashboards could be improved by adding trend-based views of assurance coverage, overdue actions, repeat findings, residual risk, supplier issues, and closure validation status.

Benefit

Enhanced dashboards would improve executive visibility, support prioritisation, and enable earlier intervention where remediation is delayed or risk exposure is increasing.

Recommendation

Develop an assurance dashboard containing:

- Open findings by rating, age, owner, and source.
- Overdue actions by business unit and accountable executive.
- Repeat findings and recurring themes.
- Closure validation status for high-rated actions.

- Assurance coverage mapped to key technology risks.
- Supplier assurance exceptions and remediation progress.
- Risk trend indicators and escalation triggers.

Improvement Opportunity IA-10 - Establish a Lessons Learned Process for Repeat Findings

Field	Detail
Rating	Improvement Opportunity
Area	Continuous improvement
Owner	[Role / Owner]
Target date	[Date]
Status	Open

Observation

Repeat or similar findings are identified across audits and reviews, but there is no formal process to analyse common root causes or share lessons learned across teams.

Benefit

A structured lessons learned process would reduce recurrence, improve control design, and support a stronger culture of continuous improvement.

Recommendation

Introduce periodic lessons learned reviews for significant and recurring findings. Outcomes should be shared with process owners, governance forums, risk management, and assurance teams.

Analysis

Overall Governance and Assurance Maturity

The organisation demonstrates a developing level of maturity in independent assurance over information and technology governance. Core structures are in place, including governance forums, risk reporting, audit tracking, and management ownership of remediation actions. However, practices are not yet consistently embedded across all relevant functions and business units.

The most important maturity gaps relate to:

- Consistency of evidence standards.
- Integration of assurance planning across functions.
- Quality and actionability of executive reporting.
- Traceability between findings, risks, actions, and control improvements.
- Independent validation of remediation for higher-risk issues.

- Visibility of supplier-related assurance results.

Root Cause Themes

The findings indicate several recurring root cause themes:

Theme	Description	Related Findings
Fragmented assurance ownership	Assurance activity is performed by multiple teams without a single consolidated view	IA-02, IA-06, IA-09
Inconsistent evidence standards	Control and issue records vary in quality and completeness	IA-01, IA-04, IA-08
Reporting not fully decision-oriented	Reports contain information but not always clear thresholds, trends, or required decisions	IA-03, IA-05, IA-09
Limited validation discipline	Some management assertions are accepted without sufficient independent review	IA-01, IA-04
Distributed third-party oversight	Supplier assurance information is not consistently assessed and escalated	IA-06
Process documentation gaps	Expectations are not always formalised in templates, guidance, or standard operating practices	IA-04, IA-07, IA-08

Risk Implications

If the findings remain unresolved, the organisation may face the following risks:

- Inaccurate reporting of remediation progress to senior management and governing bodies.
- Continued operation of ineffective or partially remediated controls.
- Assurance gaps over material technology risks and critical services.
- Duplication of assurance work and inefficient use of specialist resources.
- Weak visibility of supplier-related control issues.
- Reduced ability to demonstrate effective oversight to regulators, external auditors, customers, or contractual counterparties.
- Repeat findings and remediation fatigue.
- Delayed management response to deteriorating risk indicators.

Management Capability Assessment

Management has demonstrated willingness to engage with the assurance process and has provided access to relevant stakeholders and records. There is evidence of active governance and an established intent to improve assurance reporting. However, management capability would be strengthened by assigning clearer ownership for integrated assurance coordination and by formalising consistent standards across issue management, control self-assessment, risk reporting, and supplier assurance.

Prioritisation Assessment

Remediation should be prioritised as follows:

Priority	Focus Area	Rationale
1	Issue closure and validation	Prevents inaccurate reporting of risk reduction and control effectiveness

Priority	Focus Area	Rationale
2	Integrated assurance planning	Improves coverage of key risks and reduces duplication
3	Technology risk and metrics reporting	Improves decision quality and management oversight
4	Control self-assessment evidence standards	Strengthens reliability of management assurance
5	Third-party assurance integration	Improves visibility of supplier-related risk
6	Documentation and action tracking consistency	Improves traceability and governance discipline

Conclusion of Analysis

The organisation's assurance arrangements provide a foundation for effective oversight, but current practices require standardisation and integration. Addressing the high-rated findings should materially improve the reliability of management reporting and the quality of assurance provided to governing bodies.

Recommendations & Actions

Management Action Plan

Ref.	Recommendation	Agreed Management Action	Owner	Due Date	Success Criteria	Status
IA-01	Standardise issue closure evidence and validation	Define closure evidence standards by severity; update the issue tracker to require mandatory evidence; require independent validation for high-rated findings; report validation status to governance forums	[Role / Owner]	[Date]	All high-rated issues closed after implementation include evidence and independent validation record	Open
IA-02	Create an integrated technology assurance plan	Consolidate assurance activities from audit, risk, compliance, security, operations, supplier management, and external reviews into a risk-based annual assurance plan	[Role / Owner]	[Date]	Approved integrated assurance plan and quarterly coverage updates presented to governance forum	Open
IA-03	Improve technology risk reporting	Update risk reporting templates to include business impact, trend, residual risk, treatment effectiveness, owner, and required decisions	[Role / Owner]	[Date]	Executive risk reports consistently show business impact and risk trend for technology risks	Open
IA-04	Strengthen control self-assessment standards	Publish guidance for evidence, sampling, rating definitions, review, and escalation; train control owners	[Role / Owner]	[Date]	Control self-assessments are evidence-based and reviewed for quality before submission	Open
IA-05	Establish a technology metrics catalogue	Define approved metrics, owners, data sources, calculation rules, thresholds, and escalation requirements	[Role / Owner]	[Date]	Technology reporting uses approved metric definitions and documented thresholds	Open

Ref.	Recommendation	Agreed Management Action	Owner	Due Date	Success Criteria	Status
IA-06	Integrate third-party assurance into governance reporting	Define supplier assurance review process; log supplier issues; escalate material exceptions; link supplier findings to risk reporting	[Role / Owner]	[Date]	Supplier assurance exceptions are risk-assessed, tracked, and reported for critical services	Open
IA-07	Standardise governance action tracking	Implement a common action log template with owners, due dates, status, dependencies, and closure notes	[Role / Owner]	[Date]	Governance actions across in-scope forums are tracked using standard fields	Open
IA-08	Improve assurance documentation traceability	Define repository structure, naming convention, retention expectations, and access controls for assurance evidence	[Role / Owner]	[Date]	Evidence can be traced from report findings to supporting records within agreed retrieval time	Open
IA-09	Enhance executive assurance dashboards	Add trend views, overdue action analysis, repeat finding tracking, closure validation status, and assurance coverage maps	[Role / Owner]	[Date]	Dashboard provides current assurance and remediation insight to executive governance forums	Open
IA-10	Establish lessons learned reviews	Conduct periodic review of repeat findings and share root cause themes with relevant owners and governance bodies	[Role / Owner]	[Date]	Repeat finding themes and improvement actions are documented and tracked	Open

Remediation Milestones

Milestone	Description	Responsible Owner	Target Date
Milestone 1	Approve remediation plan and assign executive sponsors	[Role / Owner]	[Date]
Milestone 2	Define evidence standards and update issue management process	[Role / Owner]	[Date]
Milestone 3	Produce first integrated technology assurance coverage map	[Role / Owner]	[Date]
Milestone 4	Implement revised risk and metric reporting templates	[Role / Owner]	[Date]
Milestone 5	Publish control self-assessment guidance and conduct owner training	[Role / Owner]	[Date]
Milestone 6	Implement third-party assurance review workflow	[Role / Owner]	[Date]
Milestone 7	Launch enhanced executive assurance dashboard	[Role / Owner]	[Date]
Milestone 8	Complete validation of high-rated remediation actions	[Role / Owner]	[Date]

Management Response

Management acknowledges the findings and agrees that strengthening assurance coordination, evidence quality, reporting, and remediation validation will improve the reliability of technology governance oversight. Management has agreed to implement the actions listed above and will provide periodic status updates to the relevant

governance forums.

Follow-Up and Validation

Follow-up activities will be performed according to the severity of findings and agreed due dates.

Finding Rating	Follow-Up Requirement	Validation Approach
Critical	Immediate and frequent follow-up until risk is contained and remediation is complete	Executive evidence review, direct testing, and formal closure approval
High	Formal follow-up at least monthly until completion	Independent review of evidence and operating effectiveness validation where applicable
Medium	Periodic follow-up until agreed actions are complete	Evidence review and sample-based validation
Low	Follow-up through routine management reporting	Confirmation of completion and targeted evidence review
Improvement Opportunity	Follow-up where management accepts and assigns an action	Management progress update and evidence review where relevant

Closure Requirements

An action will only be marked as closed when:

- The agreed remediation has been implemented.
- Evidence is retained in the approved repository.
- The evidence addresses the original finding and root cause.
- The responsible owner confirms completion.
- Required validation has been performed based on severity.
- Residual risk has been assessed and accepted where appropriate.
- Closure is reported through the agreed governance channel.

Distribution & Confidentiality

Distribution

This report is intended for authorised recipients only.

Recipient / Group	Purpose of Distribution
Board / Audit and Risk Committee	Governance oversight and challenge
Chief Executive Officer	Executive accountability and awareness
Chief Information Officer	Management ownership of technology remediation
Chief Information Security Officer	Security-related risk and remediation oversight
Chief Risk Officer	Enterprise risk integration and monitoring
Chief Audit Executive	Assurance planning and follow-up
Compliance Officer	Compliance monitoring and regulatory alignment
Relevant Process and Control Owners	Implementation of agreed actions
External Auditors	Where approved and relevant to audit coordination
Regulators or Supervisory Bodies	Only where legally required or formally authorised

Additional distribution requires approval from [Report Owner / Chief Audit Executive / General Counsel].

Confidentiality Requirements

This report is classified as **Confidential - Internal Use Only**. It contains sensitive information regarding governance practices, control weaknesses, risk exposure, audit observations, remediation status, and third-party assurance matters.

Recipients must:

- Use the report only for authorised governance, management, audit, risk, compliance, or remediation purposes.
- Not share the report externally without prior written approval from [Authorising Role].
- Store the report only in approved repositories with appropriate access controls.
- Avoid copying report extracts into lower-classification documents unless approved.
- Protect working papers and supporting evidence in accordance with organisational information handling requirements.
- Notify [Report Owner / Information Security Contact] immediately if unauthorised disclosure is suspected.

External Release

External release of this report, in whole or in part, must be reviewed and approved by:

Approver	Approval Required For
[Chief Audit Executive]	Release to external auditors or assurance providers
[General Counsel]	Release to regulators, litigants, counterparties, or public bodies
[Chief Information Security Officer]	Release of security-sensitive content
[Executive Sponsor]	Release to strategic partners or customers where contractually required

Record Retention

The final report, management responses, supporting evidence, and follow-up validation records must be retained in accordance with the organisation's records retention requirements for audit and assurance material.

Minimum retention expectations:

Record Type	Retention Requirement	Repository
Final assurance report	[Retention Period]	[Approved Repository]
Management action plan	[Retention Period]	[Approved Repository]
Supporting workpapers	[Retention Period]	[Approved Repository]
Closure validation evidence	[Retention Period]	[Approved Repository]
Distribution and approval records	[Retention Period]	[Approved Repository]

Report Approval

Role	Name	Approval / Acknowledgement Date
Report Prepared By	[Name / Role]	[Date]
Reviewed By	[Name / Role]	[Date]
Approved By	[Name / Role]	[Date]
Management Acknowledgement	[Name / Role]	[Date]